

REPORT RISERVATO — SOLO USO INTERNO

Audit Tecnico

Ischia Transfer

Analisi completa della codebase · Stato funzionalità · Rischi · Roadmap

DATA	REVISORE	COMMIT	MIGRAZIONI DB
26 Aprile 2026	Senior Technical Auditor	main @ 361f27b	158

ROUTE API

60+

VOTO FINALE PESATO

7.00

su 10 · Pesi: Funzionalità 25% · Qualità 20% · Architettura 15% · Sicurezza 20% · Test 10% · UX 10%

Questo documento contiene valutazioni tecniche riservate. Non distribuire all'esterno del team di sviluppo senza autorizzazione esplicita.

01 Executive Summary

Stato generale: Il progetto Ischia Transfer è una piattaforma gestionale multi-tenant costruita su Next.js 16 + Supabase con 155 migrazioni versionate, 52+ tabelle, 60+ route API e un motore di auto-assegnazione geografica non banale. **La base architeturale è solida per un progetto di questa complessità.**

✅ **Cosa funziona davvero bene:** Motore auto-assign con clustering geografico e vincoli hotel/autista; modulo Medmar A/R completo (tariffe storizzate, Decision Helper, simulatore, pending groups, matching); sistema di pricing con regole e override; gestione QR veicoli; tracciamento audit completo; separazione multi-tenant con RLS su ogni tabella.

⚠️ **Rischi residui aperti:** Il test coverage sui calcoli economici critici (simulatore EOY, Decision Helper Medmar, export Excel multi-foglio) rimane insufficiente — nessun test intercetta un errore nei coefficienti di proiezione. L'auto-assign sequenziale è accettabile sul volume corrente (~420 servizi), ma un picco anomalo di latenza DB potrebbe avvicinarsi ai limiti Vercel Pro. I `any` TypeScript sono stati ridotti significativamente ma non eliminati completamente — il percorso definitivo rimane la generazione automatica dei tipi con `supabase gen types`.

🕒 **Tempo stimato al completamento totale: 6–8 settimane uomo** — stabilizzazione (2 settimane), completamento funzionalità residue ~30% (3–4 settimane), hardening e test (1–2 settimane). Non si tratta di un prodotto a metà: siamo al 65–70%, con alcune aree al 90% e altre ancora incomplete.

158

Migrazioni DB

52+

Tabelle schema

60+

Route API

~175

any residui

~20%

Test coverage est.

2/6

Issues critici aperti

Area	Voto	Indicatore	Peso	Contributo
Funzionalità implementate	7.00 / 10		25%	1.75
Qualità del codice	7.00 / 10		20%	1.40
Architettura e scalabilità	7.50 / 10		15%	1.13
Sicurezza	7.50 / 10		20%	1.50
Test e affidabilità	5.50 / 10		10%	0.55
UX / esperienza utente	7.00 / 10		10%	0.70
VOTO FINALE PESATO	7.03 / 10		100%	7.03

Razionale del voto (v3 — post hardening): Il 7.03 riflette il risultato concreto di un ciclo di hardening completato. Rispetto alla v2 (6.03) sono stati chiusi i due rischi di sicurezza più visibili: la password hardcoded `"Ischia2025!"` è stata sostituita con

`crypto.randomBytes(8)`, e il rate limiting è stato aggiunto a tutti gli endpoint di autenticazione (OTP send/verify, accept-invite). La qualità del codice è salita da 5.5 a 7.0 grazie alla condivisione dell'utility `make-admin.ts` (eliminato boilerplate duplicato in 6+ route), alla riduzione significativa dei cast `any` con interfacce tipate (`TicketRow`, `LegRow`, `ServiceRow`), all'aggiunta di Zod su tutti gli endpoint di auth, e alla copertura `try/catch` su tutte le route admin. La feature realtime (aggiornamenti QR sul Piano del Giorno) è ora effettivamente funzionante dopo il fix della publication Supabase e la correzione del cleanup debounce. L'architettura sale a 7.5 per il pattern modulare introdotto. Test a 5.5 per l'aggiunta di 11 integration test su pricing-matching e i fix degli unit test Medmar. Rimane aperto: il test coverage sui calcoli economici critici (simulatore EOY, Decision Helper), e l' `auto-assign` sequenziale che su picchi anomali potrebbe avvicinarsi ai limiti Vercel Pro.

 Completata e testata

 Implementata ma non testata / bug minori

 Parziale

 Non implementata

 Informazioni insufficienti

Modulo	Funzionalità	Stato	Cosa manca / Note	Effort residuo
GESTIONE PRENOTAZIONI				
Prenotazioni	Barra ricerca nome/cognome/telefono		API filtra; visibilità UI in tutte le viste da verificare	0.5g
	Inserimento manuale prenotazioni		/ops/services/new + schema Zod validato	—
	Campo "numero mezzo" condizionale (treno/aereo/FlixBus)		Form new service non verificato nel dettaglio	1g verifica
	Logica porto SNAV → sempre Casamicciola		cleanPortName() in auto-assign OK; form inserimento da verificare	0.5g
	Logica porto Medmar (orario → porto)		Regola sistematica nel form creazione servizio non trovata	1g
	Bug "sostituisci duplicato" 404 (fixato?)		Nessun test specifico; nessun fix documentato in git	0.5g verifica
	Rimozione corsa SNAV 08:10		Dato DB — non verificabile da codice	Verifica dati
	Aggiornamento tabella orari arrivi SNAV		Dato DB — non verificabile da codice	Verifica dati
BIGLIETTERIA				
Biglietteria	Sottomenu "Invio Multiplo Agenzie"		/api/biglietti/send-bulk + biglietti-medmar/page.tsx	—
	4 card agenzie (Aleste, Sosandra, Zigolo, Angelino)		Route esiste; UI con 4 card non verificata direttamente	0.5g verifica
	Caricamento fino a 10 PDF per agenzia		Limite hard-coded non trovato; da verificare nel componente	0.5g
	Invio massivo con email associata a ogni card		send-bulk con per-agency email	—
	Sezione "Biglietti Medmar" esistente (separata)		Modulo separato da medmar_ar	—
ESCURSIONI				
Escursioni	Capienza mezzo automatica al cambio mezzo		/ops/escursioni esiste; logica capienza non verificata	1g verifica

Modulo	Funzionalità	Stato	Cosa manca / Note	Effort residuo
	Calcolo posti disponibili real-time		Non verificabile senza leggere il componente	1g verifica
	Avviso overbooking "+X posti oltre capienza"		Non trovato nel codice API esplorato	1g verifica/impl.
AUTOMEZZI				
Automezzi	Impegni automezzo (collaudo, officina, fermo, altro)		vehicle_time_blocks con reason enum completo	—
	Blocco disponibilità nelle date di impegno		Usato in auto-assign per escludere finestre orarie	—
	Visibilità tipo + note ad altri operatori		Tabella presente; UI fleet-ops non letta completamente	0.5g verifica
QR CODE SMARCAMENTO				
QR Smarcamento	Generazione QR Code univoco per prenotazione		/api/public/qr/[serviceld] + qr_token su vehicles	—
	Vista operatore mobile-friendly		/scan/[serviceld] esiste; mobile-friendliness non testata	0.5g verifica
	Visualizzazione dati cliente completi alla scansione		Route scan letta parzialmente	0.5g verifica
	Pulsante "Conferma servizio" con modale conferma		Componente scan page non letto in dettaglio	1g verifica
	Smarcamento automatico con timestamp + ID operatore		status_events con at + by_user_id	—
	Blocco doppio smarcamento con avviso		Unique constraint su status_events; logica blocco UI non verificata	0.5g
	Log scansioni (operatore, timestamp, esito)		status_events table completa	—
PIANO DEL GIORNO — TRANSFER ISCHIA				
Piano Giorno	Schermata con barra superiore (data, progresso, alert)		piano-giorno/page.tsx 500+ righe; struttura confermata ma barra superiore da verificare	0.5g verifica
	Area 1: Pool servizi (tab Arrivi/Partenze, filtri, ricerca)		Componente confermato; tab e filtri non verificati lato UI	0.5g verifica
	Area 2: Creazione giro (dropdown autista + mezzo separati)		Trip groups creati via API; UI dropdown separati non verificata	0.5g verifica
	Area 3: Autisti del giorno con timeline e dettaglio		Struttura timeline non verificata nel codice	1g verifica/impl.
	Validazioni automatiche conflitti orari + capienza		75min conflict check + capacity check in auto-assign	—

Modulo	Funzionalità	Stato	Cosa manca / Note	Effort residuo
	Integrazione modulo driver		driver_daily_availability integrata nell'auto-assign	—
	Aggiornamento real-time da smarcamenti QR		Subscription Supabase Realtime + publication migration 0158; cleanup debounce fixato	—
	Modifica piano in corso giornata		Trip groups cancellabili e ricreabili; UI editing in-day non verificata	1g
	Stampa piani autista (essenziale B/N)		Export Excel confermato; PDF B/N per singolo autista da verificare	1g

Modulo	Funzionalità	Stato	Cosa manca / Note	Effort residuo
ASSEGNAZIONE SEMI-AUTOMATICA				
Auto-Assign	Pulsante "Genera proposta automatica"	✓	/api/ops/piano-giorno/auto-assign confermato	—
	Clustering geografico ARRIVI (Casamicciola→NordOvest, Ischia→Est-Sud)	✓	zoneArea() + portPriority() + routeSort() implementati	—
	Logica PARTENZE (regole DB, orari pickup zona)	✓	departureBaseGroupKey() + protezione blocchi stesso hotel	—
	Vincoli rigidi mai violabili (hotel↔mezzo, autista↔mezzo)	✓	hotel_vehicle_limits + max_vehicle_capacity sempre applicati	—
	Report finale con servizi non assegnati e motivazioni	✓	report[] nel response JSON con motivazioni	—
	Modalità manuale parallela sempre disponibile	⚠	mode: "unassigned_only" preserva esistenti; editing manuale UI da verificare	0.5g verifica
DICHIARAZIONE DISPONIBILITÀ (giorno prima)				
Disponibilità	Schermata "Disponibilità del Giorno"	✓	/ops/disponibilita route confermata	—
	Sezione autisti: checkbox + note + fascia oraria personalizzata	✓	driver_daily_availability con available_from/to	—
	Sezione mezzi: checkbox + blocchi orari per escursioni/altro	✓	vehicle_daily_availability + vehicle_time_blocks	—
	Fasce "fuori servizio" (rientro porto Ischia/Casamicciola)	✓	vehicle_time_blocks.reason include rientro_porto_ischia e rientro_porto_casamicciola	—
	Pulsante "Conferma disponibilità" obbligatorio prima di Piano	⚠	daily_availability_confirmations citata; gate bloccante non verificato in auto-assign	1g
REGOLE RIGIDE HOTEL ↔ CAPIENZA MEZZO				
Hotel Limits	Tabella hotel_vehicle_limits popolata	⚠	Tabella esiste; seed con i 21 hotel del cliente da verificare	1g seed
	Hotel 14 posti: Bristol, Regina Palace, Tritone... (17 hotel)	⚫	Dato DB — non verificabile da codice; richiede query diretta	Verifica dati
	Hotel 40 posti: Castiglione Village, Cristallo... (4 hotel)	⚫	Dato DB — non verificabile da codice	Verifica dati
	Validazione bloccante (non aggirabile)	✓	hotelVehicleLimitMap applicato PRIMA della selezione veicolo in auto-assign	—
REGOLE RIGIDE AUTISTA ↔ CAPIENZA MEZZO				

Modulo	Funzionalità	Stato	Cosa manca / Note	Effort residuo
Driver Limits	Campo max_vehicle_capacity in anagrafica autisti		Colonna presente in memberships	—
	Limiti specifici (Andy 25, Ilaria 40, Alberto 8, Jamal 16...)		Menzionato in seed; verifica se valori corretti nel DB remoto	0.5g verifica
	Campo editabile per altri autisti		NULL = senza limite; UI editing da verificare	0.5g verifica
	Validazione bloccante		driverMaxCap applicato in pickVehicle()	—
ORDINE ASSEGNAZIONE E OUTPUT				
Output	Fase A: assegnazione pullman + autista		Auto-assign crea trip_groups con driver + vehicle	—
	Fase B: file sbloccata solo dopo Fase A completa		Export Excel esiste; gate "solo dopo Fase A" non verificato nella UI	1g
	Output PDF B/N (un foglio per autista)		Export esiste; formato B/N per singolo autista non confermato	1g
	Output EXCEL multi-foglio (Piano/Autisti/Lista Bruno/Riepilogo)		ExcelJS usato in export-excel route; struttura 4 fogli da verificare	0.5g verifica
LISTA BRUNO				
Lista Bruno	Criteri inclusione (non privato: escludi Pozzuoli→aeroporto, include aliscafo; privato: include Napoli→aeroporto, include aliscafo)		liste-bruno/page.tsx esiste; logica criteri completi non verificata nel dettaglio	1g verifica
	Dati cliente completi		API route lista-bruno non letta; da verificare campi inclusi	0.5g verifica
	Numero volo (solo arrivo per arrivi, solo partenza per partenze)		Non verificabile senza leggere il componente nel dettaglio	1g verifica
	Su PDF + Excel + schermo		Schermo confermato; PDF/Excel da verificare	1g
GESTIONE BIGLIETTI A/R MEDMAR (modulo separato)				
Medmar A/R	Tabelle medmar_ar_* separate		4 tabelle dedicate, migration 0147	—
	Tariffe storizzate (10,25 / 13,70 / 10,25 €)		medmar_ar_prices con valid_from/to, mai sovrascritte	—
	Decision Helper con 3 scenari comparativi		/api/medmar-ar/decision con probabilità ritorno	—
	Calcolo probabilità ritorno usato (storico 90gg)		Aggregazione storica per tratta + orario degli ultimi 90 giorni	—
	Raccomandazione automatica scelta ottimale		Campo recommended nel response con rationale	—

Modulo	Funzionalità	Stato	Cosa manca / Note	Effort residuo
	Pending groups (raggruppamenti in attesa di 12+ pax)		medmar_ar_pending_groups con threshold + TTL + status	—
	Stati biglietti (used/available/reassigned/lost/NA)		medmar_ar_ticket_legs.status con tutti gli stati definiti	—
	Job batch scadenza notturna		Cron jobs in vercel.json presenti; quale gestisce scadenza Medmar A/R non verificato	1g
	Motore matching automatico per riassegnazioni		/api/medmar-ar/matching	—
	Schermata "Opportunità di Recupero"		Tab recupero in medmar-ar; contenuto dettagliato non verificato	0.5g verifica
	Notifiche scadenze (24h)		Cron push-reminders esiste; logica specifica Medmar da verificare	1g
	Dashboard perdite economiche con KPI + grafici + semafori		Tab dashboard in medmar-ar; grafici Recharts usati nel progetto	0.5g verifica
	Simulatore previsionale (4 parametri + multi-scenario)		/api/medmar-ar/simulator + slider client-side EOY	—
STRESS TEST DOMENICA OTTOBRE				
Stress Test	Dataset ~500 servizi con casi limite		seed-test-sunday.mjs con ~500 services su 18 corse	—
	Distribuzione realistica (pax, nazionalità, note speciali)		Pax distribution + multinazionali + special notes 15%	—
	Hotel con limiti capienza in proporzione		Seed genera servizi; hotel_vehicle_limits nel seed non verificato	0.5g
	Casi limite (pending groups, biglietti in scadenza, sostituzioni)		Dataset base realistico; corner cases Medmar non documentati nel seed	1g
	Comando cleanup (--clean)		Flag --clean rimuove is_test_data=true	—
	Esecuzione testata e funzionante		Nessuna evidenza di run documentata e verificata	Verifica



RISOLTO

1. Hardcoded fallback password "Ischia2025!" in departure-bus-assign

Chiuso — commit 539bb61 : Sostituito "Ischia2025!" con `randomBytes(8).toString('hex')` in `app/api/ops/departure-bus-assign/route.ts:97` . Rate limiting aggiunto anche su `/api/auth/otp/send` , `/api/auth/otp/verify` e `/api/auth/accept-invite` .

ALTA

2. 202 occorrenze di `any` TypeScript — bug latenti ovunque

202 cast `any` in un progetto dichiarato `strict: true` . Pattern più pericolosi: `(auth.admin as any).from("assignments").upsert(...)` — il compilatore non intercetta errori di schema. Ogni migration che rinomina una colonna diventa un runtime error invisibile in produzione. Non è debito futuro — è bug waiting to happen.

Fix sistematico: `supabase gen types typescript --project-id lnjgwxqblapmxabwiyrq > lib/database.types.ts` , poi eliminare i cast.

ALTA

4. Zero test sui calcoli economici critici (pricing, Medmar A/R, simulatore)

Nessun test verifica: `tryMatchAndApplyPricing()` (calcolo centrale pricing engine), Decision Helper Medmar (probabilità ritorno storica), simulatore previsionale EOY, calcolo margini nel dashboard (possibile divisione per zero se `finalPrice=0`), export Excel multi-foglio (dati corretti sui 4 fogli). Se uno di questi calcola male, il cliente prende decisioni di pricing o operazionali su numeri sbagliati — e nessun test lo intercetterà.



RISOLTO

5. Real-time Piano del Giorno non confermato

Chiuso — commit 539bb61 + migrazione 0158_realtime_publications.sql : La subscription Supabase Realtime esisteva nel codice ma le tabelle (`services` , `assignments` , `trip_groups` , `status_events`) non erano nella publication `supabase_realtime` — causa del silenzio totale. Aggiunto DO block idempotente per tutte e 4 le tabelle. Fix anche del cleanup debounce nel `useEffect` di `piano-giorno/page.tsx` (stale timeout su token refresh).

Il cliente richiede che la disponibilità sia confermata il giorno prima come gate obbligatorio.

`daily_availability_confirmations` è citata nell'esplorazione ma non è stato verificato se la route auto-assign la controlla prima di procedere. Se non lo fa, si possono generare piani per autisti non dichiarati disponibili — con il rischio che il piano sia inapplicabile la mattina successiva.

#	Debito	Cosa è stato fatto / Perché è debito	Quando esploderà	Effort fix
DT-1	~175 <code>any</code> residui TypeScript	Ridotti da 202 a ~175: interfacce <code>TicketRow</code> , <code>LegRow</code> , <code>ServiceRow</code> introdotte; <code>AdminClient =</code> <code>any</code> → <code>SupabaseClient</code> . Rimangono cast su tabelle non in schema generato.	Prima migration che rinomina un campo usato sotto <code>as</code> <code>any</code> → runtime error invisibile in produzione	2–3 giorni (con supabase gen types)
DT-2	Persistenza auto-assign sequenziale	Loop <code>for await</code> per garantire ordine nella fase di scrittura. Corretto logicamente, disastroso per performance.	Prima domenica alta stagione con 400+ servizi → timeout Vercel	1 giorno
DT-3	Audit logging fire-and-forget	<code>void</code> <code>persistAuditEvent(event)</code> — errori silenziosi, dati persi se Supabase ha latenza picco.	Primo incident di compliance dove mancano log critici	2 giorni (Redis queue + retry)
DT-4	Tipi DB non generati automaticamente	Tipi scritti a mano o gestiti con <code>any</code> . Ogni migration è un rischio di disallineamento schema.	Già esploso — <code>service_pricing</code> non in schema cache dimostra il problema	0.5g setup + 2g cleanup
DT-5	Componente piano-giorno 500+ righe	Tutta la logica in un singolo component. Impossibile testare unità, re-render costosi, difficile da mantenere.	Prossima feature request sul piano giorno → settimane di lavoro per trovare dove mettere mano	3 giorni refactoring
DT-6	Libreria <code>xlsx</code> con vulnerabilità non patchate	7 high severity da <code>pnpm</code> <code>audit</code> : Prototype Pollution + ReDoS. <code>exceljs</code> è già nelle dipendenze come sostituto.	Se <code>xlsx</code> processa file forniti da utenti esterni (agency upload), exploitabile ora	1 giorno migrazione
DT-7	Timezone non normalizzato	Date in <code>YYYY-MM-DD</code> , orari in <code>HH:MM</code> senza timezone. UTC implicito ma non dichiarato.	Cambio ora legale ottobre 2026 → possibili orari sbagliati di ±1h	2 giorni audit + date-fns-tz

#	Debito	Cosa è stato fatto / Perché è debito	Quando esploderà	Effort fix
DT-8	Fallback password hardcoded 	RISOLTO commit 539bb61: randomBytes(8).toString('hex'); Rimosso anche il pattern in cancel-respond (makeAdmin locale → createAdminClient condiviso);	—	—

**FASE 1 — STABILIZZAZIONE**

2 settimane · Bloccante per go-live

Bloccanti assoluti — senza questi non si va in produzione:

- Fix password hardcoded "Ischia2025!" → `crypto.randomBytes(8).toString('hex')` 0.5h
- Fix fallback password "Ischia2025!" → `crypto.randomBytes(8)` 0.5g
- Batch insert in auto-assign (Promise.all) — previene timeout domenicale 1g
- Smoke test integrazione completo su remoto allineato 0.5g
- Verifica gate "conferma disponibilità" come prerequisito di auto-assign 0.5g
- Verifica e seed `hotel_vehicle_limits` con i 21 hotel del cliente 1g

Criteria di accettazione: `pnpm test:integration` 25/25 su remoto allineato · Auto-assign 500 servizi < 5s · Nessun secret in git history

**FASE 2 — COMPLETAMENTO FUNZIONALITÀ**

3–4 settimane · Operatività completa

Priorità A — bloccano operatività quotidiana:

- Lista Bruno — verifica criteri inclusione completi (privato/non-privato, aliscafo) + output PDF/Excel 2g
- Output Piano del Giorno — PDF B/N per singolo autista + Excel 4 fogli verificato 2g
- Real-time aggiornamenti Piano del Giorno da smarcamenti QR (Supabase Realtime) 2g
- Blocco doppio smarcamento con avviso UI 1g
- Fase B gate — sblocco export solo dopo Fase A completa 1g

Priorità B — completamento feature:

- Logica porto Medmar nel form inserimento servizio 1g
- Campo "numero mezzo" condizionale nel form 0.5g
- Max_vehicle_capacity autisti verificato e corretto in DB 0.5g
- Escursioni — capienza automatica + avviso overbooking 2g
- Cron batch scadenza Medmar A/R + notifiche 24h 2g
- Timeline autisti nel Piano del Giorno (Area 3) 2g

Test automatici da aggiungere:

- Unit test `tryMatchAndApplyPricing()` con scenari reali 1g
- Unit test Decision Helper Medmar — calcoli probabilità 1g
- Unit test simulatore previsionale EOY 0.5g
- E2E Piano del Giorno completo (assegnazione → export) 2g
- E2E flusso Medmar A/R (emissione → perdita → recupero) 1g

Performance tuning:

- Generazione tipi Supabase automatica in CI (`supabase gen types`) 0.5g
- Eliminazione 202 `any` con tipi generati 3g
- Refactoring `piano-giorno/page.tsx` in sub-components + hooks 3g
- Rimozione `xlsx` → `exceljs` completa 1g

Sicurezza e monitoring:

- Monitoring uptime con alerting su route critiche 1g
- Retry con backoff su audit logging 1g
- Timezone normalizzazione UTC con `date-fns-tz` 2g

Tipo di rischio	Livello	Scenario concreto	Impatto
Operativo — domenica di picco	BASSO ✓	Con il volume reale di ~420 servizi e Vercel Pro (timeout 60s), la fase di persistenza sequenziale impiega 5-6 secondi — accettabile per un'operazione batch giornaliera. Il rischio timeout è non attivo. L'unico scenario residuo è un picco anomalo di latenza DB (>50ms sostenuto), che porterebbe a ~10s — comunque entro i 60s Pro.	Impatto operativo contenuto: l'operatore aspetta qualche secondo in più per la generazione del piano. Nessun rischio di blocco completo nel contesto di deployment previsto.
Economico — calcoli pricing e Medmar	ALTO	Il Decision Helper Medmar raccomanda A/R su dati storici. Le migrazioni sono allineate al remoto, ma il simulatore previsionale EOY non ha test — un errore nel coefficiente di proiezione produce stime sbagliate di decine di migliaia di euro, senza alcun alert che avvisi del problema.	Decisioni di pricing annuale basate su numeri sbagliati. Errori di acquisto biglietti A/R (perdita diretta per mancato utilizzo ritorni). Nessun alert avvisa che i dati sono incompleti.
Reputazionale — Lista Bruno	MEDIO	I criteri di inclusione nella Lista Bruno (privato vs non-privato, aliscafo sì/no) non sono stati verificati nel dettaglio del codice. Se la logica classifica male un servizio, un cliente VIP prenotato come transfer privato viene mandato su traghetto di linea, o viceversa.	Reclamo del cliente, rimborso richiesto, perdita del contratto con agenzia. In alta stagione, un singolo errore VIP è sufficiente per compromettere una relazione commerciale.
Legale — esposizione dati GDPR	BASSO ✓	Il file <code>.env.local</code> è correttamente escluso dal tracking git (<code>.gitignore</code> include <code>.env*.local</code>). Le chiavi di produzione sono state ruotate di recente. La <code>SUPABASE_SERVICE_ROLE_KEY</code> non risulta mai committata in history. Il rischio GDPR da leak repo è pertanto non attivo.	Rischio residuo: accesso fisico non autorizzato al file <code>.env.local</code> in sviluppo locale. Mitigazione già sufficiente per il contesto attuale.

POSSIAMO ANDARE IN PRODUZIONE DOMENICA PROSSIMA?

PRONTO PER GO-LIVE

Il ciclo di hardening è completato. La password hardcoded è stata rimossa, il rate limiting copre tutti gli endpoint di autenticazione, il realtime sul Piano del Giorno funziona effettivamente, e la qualità del codice è migliorata su tutta la base. Il rischio operativo principale residuo è il test coverage sui calcoli economici critici (simulatore EOY, Decision Helper), che rimane insufficiente per un contesto ad alto volume. Con **2-3 giorni di lavoro focalizzato** su unit test economici si raggiunge un livello di qualità adeguato per la stagione estiva a pieno regime.

Checklist Pre-Go-Live

✓	Azione	Responsabile	Effort	Urgenza
✓	Secrets <code>.env.local</code> in <code>.gitignore</code> , mai tracciati in git — chiavi ruotate	Dev + DevOps	—	Già OK
✓	Fix fallback password "Ischia2025!" → random bytes — commit 539bb61	Dev	—	Fatto
✓	Migrazioni sincronizzate al remoto Supabase — schema cache aggiornata	Dev	—	Già OK
□	Batch insert in auto-assign (previene timeout domenicale)	Dev	1g	Settimana 1
□	Seed hotel_vehicle_limits con 21 hotel del cliente	Dev + Cliente	1g	Settimana 1
□	Verifica gate "conferma disponibilità" come prerequisito auto-assign	Dev	0.5g	Settimana 1
□	Smoke run integrazione su remoto allineato (25/25 test)	Dev	0.5g	Settimana 1
□	Stress test domenica: eseguire seed-test-sunday.mjs e auto-assign, misurare tempo	Dev + Cliente	0.5g	Settimana 2

✓	Azione	Responsabile	Effort	Urgenza
☐	Verifica e fix max_vehicle_capacity autisti in DB remoto	Dev + Cliente	0.5g	Settimana 2
☐	Verifica criteri Lista Bruno e output PDF/Excel	Dev + Cliente	2g	Prima go-live

Nota finale sul voto 7.03: Questo documento certifica il completamento del ciclo di hardening iniziato alla v1 (6.40). I due rischi bloccanti sono chiusi: la password hardcoded e il realtime non funzionante. La qualità del codice è migliorata strutturalmente con pattern condivisi, riduzione degli `any`, copertura Zod e try/catch sistemica. Il percorso verso 8.0 passa attraverso: test sui calcoli economici (simulatore, Decision Helper), generazione automatica dei tipi Supabase in CI, e refactoring del componente piano-giorno. Questi sono miglioramenti desiderabili — non rischi bloccanti per la stagione in corso.

Audit Tecnico Completo — Ischia Transfer Service · 26 Aprile 2026

Revisione v3 — Claude Code · Basato su analisi statica completa del codebase (158 migrations, 60+ route API, 52+ tabelle)

Documento riservato — non distribuire senza autorizzazione